

SELinux - система принудительного контроля доступа

Введение в SELinux

Установка

Пользователь SELinux (user)

Роль (role)

Тип (type)

Уровень (level)

Переходы доменов

Контексты SELinux для процессов

Окружение

- **Версия ОС:** 8
- **Конфигурация ОС:** Рабочая станция
- **Редакция ОС:** Стандартная, Образовательная

SELinux (**S**ecurity **E**nhanced **L**inux) обеспечивает усиление защиты путем внесения изменений как на уровне ядра, так и на уровне пространства пользователя. Далее описываются основные принципы, на которых построена работа SELinux, а также их реализация в РЕД ОС.

Введение в SELinux

Стандартная политика доступа, основанная на разрешениях пользователя, группы и других правах, известная как **разграничительный контроль доступа** (Discretionary Access Control, DAC), не позволяет системным администраторам создавать комплексные и детальные политики безопасности, такие как ограничение доступа определенных приложений только к просмотру файлов журналов, при этом позволяя другим приложениям добавлять новые данные в файлы журналов.

SELinux реализует **обязательный контроль доступа** (*Mandatory Access Control, MAC*). Каждый процесс и системный ресурс имеют специальную метку безопасности, известную как **контекст SELinux**.

Политика **SELinux** использует эти контексты в серии правил, которые определяют, как процессы могут взаимодействовать друг с другом и различными системными ресурсами. По умолчанию политика не допускает никакого взаимодействия, если только правило явно не предоставляет доступ.

Примечание.

Контексты **SELinux** имеют несколько полей:

- пользователь,
- роль,
- тип,
- уровень безопасности.

Ниже приведен пример, демонстрирующий использование контекстов **SELinux**. Контексты **SELinux** применяются к процессам, пользователям Linux и файлам в операционных системах, где активирован **SELinux**. Для просмотра контекста **SELinux** файлов и каталогов используйте следующую команду:

```
ls -Z file1
```

```
-rwxrw-r-- user1 group1 unconfined_u:object_r:user_home_t:s0 file1
```

Контексты **SELinux** следуют синтаксису **SELinux user:role:type:level**. Рассмотрим каждое поле подробнее.

Установка

Для установки **SELinux** требуется установить пакет **selinux-policy**. Это можно сделать, например, воспользовавшись командной строкой с привилегиями пользователя **root**:

```
sudo dnf install selinux-policy
```

После перезагрузки **SELinux** проиндексирует содержимое жёсткого диска, это может занять некоторое время.

Для ручной настройки **SELinux** необходимо отредактировать файл конфигурации **/etc/selinux/config**.

Пользователь SELinux (user)

Идентификатор пользователя SELinux — это идентификатор, известный политике, который авторизован для выполнения определенного набора ролей и для доступа к заданному диапазону уровней безопасности (**MLS/MCS**). Каждый пользователь Linux сопоставляется с пользователем SELinux с помощью политики SELinux, что позволяет пользователям Linux наследовать ограничения, установленные для соответствующих пользователей SELinux. Сопоставленный идентификатор пользователя SELinux используется в контексте SELinux для процессов в этом сеансе, определяя, какие роли и уровни доступны этим процессам.

Для просмотра списка сопоставлений между учетными записями пользователей SELinux и Linux выполните следующую команду от имени **суперпользователя** (предварительно необходимо установить пакет **policycoreutils-python**):

```
sudo semanage login -l
```

Login Name	SELinux User	MLS/MCS Range	Service
<code>__default__</code>	<code>unconfined_u</code>	<code>s0-s0:c0.c1023</code>	<code>*</code>
<code>root</code>	<code>unconfined_u</code>	<code>s0-s0:c0.c1023</code>	<code>*</code>
<code>system_u</code>	<code>system_u</code>	<code>s0-s0:c0.c1023</code>	<code>*</code>

Вывод может немного отличаться в зависимости от системы:

- в столбце **Login Name** перечислены пользователи Linux;
- в столбце **SELinux User** указано, какому пользователю SELinux сопоставлен пользователь Linux. Этот параметр определяет, какие роли и уровни доступны для процессов этого пользователя;
- столбец **MLS/MCS Range** представляет собой диапазон уровней, используемых системой многоуровневой безопасности (MLS) и многокатегорийной безопасности (MCS);
- столбец **Service** устанавливает соответствующий контекст SELinux, в котором пользователь Linux должен входить в систему. По умолчанию используется символ звездочки (*), который означает любую службу.

По умолчанию все пользователи Linux в РЕД ОС, включая пользователей с административными привилегиями, сопоставляются с неограниченным пользователем SELinux **unconfined_u**. Повысить уровень безопасности системы можно, назначив пользователям ограниченные SELinux-контексты.

Обратите внимание, что `system_u` является специальным идентификатором пользователя для системных процессов и объектов, а `system_r` — соответствующей ему ролью. Администраторы никогда не должны связывать `system_u` и `system_r` с пользователями Linux.

Роль (role)

Модель безопасности **SELinux** включает механизм управления доступом на основе ролей (**RBAC**). Роль является атрибутом **RBAC**. Пользователи **SELinux** авторизуются для ролей, а роли авторизуются для доменов. Роль выступает посредником между пользователями **SELinux** и доменами, определяя, в какие домены можно перейти. Это ограничение влияет на доступ к различным объектам, снижая риск атак, связанных с повышением привилегий.

Уровень (level)

Уровень является атрибутом моделей обязательного контроля доступа — **MLS** и **MCS**. Диапазон уровня в **MLS** — это пара значений **lowlevel-highlevel** (если уровни различны) или **lowlevel** (если они одинаковы, например, **s0** эквивалентно **s0-s0**). Каждый уровень — это пара "**чувствительность-категория**", где категории являются необязательными. Уровень может выглядеть так:

- если есть категории, уровень записывается как "чувствительность: категория-набор";
- если категорий нет, он записывается как "чувствительность". Если набор категорий непрерывен, его можно сократить. Например, **c0.c3** то же самое, что и **c0,c1,c2,c3**.

Ф а й л **/etc/selinux/targeted/setrans.conf** сопоставляет уровни (**s0:c0**) с удобочитаемой формой. В операционной системе РЕД ОС целевая политика **SELinux** обеспечивает поддержку **MCS**. В рамках **MCS** существует только одна чувствительность (**s0**), но поддерживается до **1024** различных категорий от **c0** до **c1023**. Запись **s0-s0:c0.c1023** — это чувствительность **s0**, разрешенная для всех категорий.

MLS обеспечивает соблюдение модели обязательного контроля доступа и используется в средах с защитой на основе меток (**Labeled Security Protection Profile, LSPP**). Для использования ограничений **MLS** необходимо установить пакет **selinux-policy-mls** и настроить **MLS** в качестве политики **SELinux** по умолчанию.

Политика **MLS**, поставляемая с РЕД ОС, исключает множество программных доменов, которые не входили в состав сертифицированной конфигурации, поэтому использование **MLS** на настольной рабочей станции затруднено (отсутствует поддержка **X Window System**). Однако возможно создание собственной политики **MLS** на базе вышестоящей справочной политики **SELinux**, охватывающей все необходимые программные домены.

Тип (type)

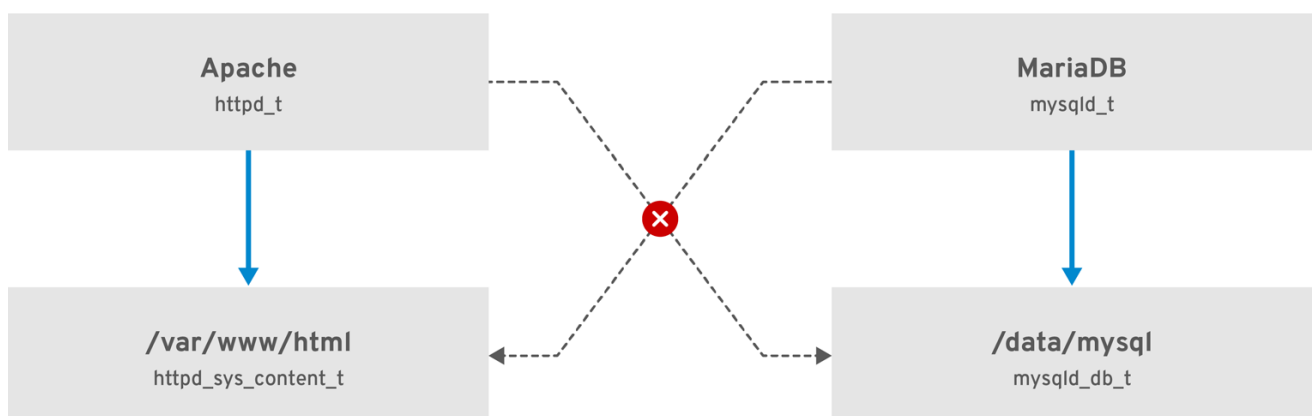
Тип является атрибутом принудительного контроля типов (**Type Enforcement**). Тип определяет домен для процессов и тип для файлов. Политика **SELinux** содержит правила, регулирующие взаимодействие между типами: как процессы одного типа могут взаимодействовать с объектами другого типа, либо как процессы разных типов могут взаимодействовать друг с другом. Доступ разрешается только тогда, когда соответствующее правило политики **SELinux** явно допускает такое взаимодействие.

Информация о типах SELinux играет ключевую роль, когда речь идет о политике SELinux, поскольку наиболее распространенное правило политики, которое определяет допустимые взаимодействия между процессами и системными ресурсами, использует типы SELinux, а не полный контекст SELinux. Типы SELinux оканчиваются на `t`.

Например:

- тип для веб-сервера — `httpd_t`;
- контекст типа для файлов и каталогов, обычно находящихся в `/var/www/html/` — `httpd_sys_content_t`;
- контекст типа для файлов и каталогов, обычно находящихся в `/tmp`, `/var/tmp/` — `tmp_t`;
- контекст типа для портов веб-сервера — `http_port_t`.

Существует правило политики, которое разрешает **Apache** (процесс веб-сервера, работающий как `httpd_t`) получать доступ к файлам и каталогам с контекстом, который обычно находится в `/var/www/html/` и других каталогах веб-сервера (`httpd_sys_content_t`). В политике нет разрешающего правила для файлов, которые обычно находятся в `/tmp` и `/var/tmp/`, поэтому доступ не разрешен. С SELinux, даже если **Apache** скомпрометирован, и вредоносный скрипт получает доступ, он все равно не может получить доступ к каталогу `/tmp`.



Как показывает предыдущая схема, SELinux разрешает процессу **Apache**, запущенному как `httpd_t`, доступ к каталогу `/var/www/html/` и запрещает этому же процессу доступ к каталогу `/data/mysql/`, поскольку для контекстов типа `httpd_t` и `mysqld_db_t` не существует разрешающего правила. С другой стороны, процесс **MariaDB**, запущенный как `mysqld_t`, может получить доступ к

каталогу `/data/mysql/`, и SELinux также правильно запрещает процессу с типом доступ `mysqld_t` к каталогу `/var/www/html/`, помеченному как `httpd_sys_content_t`.

Переходы доменов

Процесс в одном домене переходит в другой домен, выполняя приложение, имеющее тип `entrypoint` для нового домена. Разрешение `entrypoint` в политике SELinux определяет, какие приложения могут запускать процессы в определенном домене. Это помогает контролировать доступ процессов к связанным с этим доменом ресурсам. Следующий пример демонстрирует переход домена.

Пример перехода домена

1. Пользователь хочет изменить свой пароль. Для этого он запускает утилиту `passwd`. Исполняемый файл `/usr/bin/passwd` помечен типом `passwd_exec_t`:

```
ls -Z /usr/bin/passwd
```

```
-rwsr-xr-x. 1 root root system_u:object_r:passwd_exec_t:s0 32048 ноя 13 2023  
/usr/bin/passwd
```

Утилита `passwd` обращается к каталогу `/etc/shadow`, который помечен типом `shadow_t`:

```
ls -Z /etc/shadow
```

```
system_u:object_r:shadow_t:s0 /etc/shadow
```

2. Правило политики SELinux устанавливает, что процессам, запущенным в домене `passwd_t`, разрешено читать и записывать файлы, помеченные типом `shadow_t`. Тип `shadow_t` применяется только к файлам, которые требуются для смены пароля. Сюда входят `/etc/gshadow`, `/etc/shadow` и их резервные файлы.

3. Правило политики SELinux устанавливает, что для процессов, запускаемых в домене `passwd_t`, точкой входа служит объект типа `passwd_exec_t`.

4. Когда пользователь запускает утилиту `passwd`, процесс оболочки пользователя переходит в домен `passwd_t`. В SELinux, поскольку действие по умолчанию — отказать, существует правило, которое позволяет приложениям, работающим в домене `passwd_t`, получать доступ к файлам, помеченным типом `shadow_t`, приложению `passwd` разрешается получать доступ `/etc/shadow` и обновлять пароль пользователя.

Этот пример не является исчерпывающим и используется в качестве базового примера для объяснения перехода домена. Хотя есть фактическое правило, которое позволяет субъектам, работающим в домене `passwd_t`, получать доступ к объектам, помеченным типом файла `shadow_t`, другие правила политики SELinux должны быть соблюдены, прежде чем субъект сможет перейти в новый домен. В этом примере **Type Enforcement** обеспечивает:

- В домен `passwd_t` можно войти только путем выполнения приложения, помеченного этим типом `passwd_exec_t`; можно выполнять только из авторизованных общих библиотек, таких как тип `lib_t`; и нельзя выполнять никакие другие приложения.
- Только авторизованные домены, такие как `passwd_t`, могут записывать в файлы, помеченные типом `shadow_t`. Другие процессы не могут записывать в файлы, помеченные типом `shadow_t`, поскольку они не запущены в домене `passwd_t`, даже если они запущены с привилегиями суперпользователя.
- Только авторизованные домены могут перейти в домен `passwd_t`. Например, процесс `sendmail`, работающий в домене `sendmail_t`, не имеет законной причины для выполнения `passwd`; поэтому он никогда не сможет перейти в домен `passwd_t`.
- Процессы, запущенные в домене `passwd_t`, могут читать и писать только в разрешенные типы, такие как файлы, помеченные типами `etc_t` или `shadow_t`. Это предотвращает скомпрометированному `passwd`, читать или записывать произвольные файлы.

Контексты SELinux для процессов

Используйте команду `ps -eZ` для просмотра контекста SELinux для процессов.

Запустите утилиту `passwd`, не вводите новый пароль:

```
passwd
```

```
Changing password for user user_name.  
Changing password for user_name.  
(current) UNIX password:
```

Откройте новую вкладку или другой терминал и введите следующую команду. Вывод будет похож на следующий:

```
ps -eZ | grep passwd
```

```
unconfined_u:unconfined_r:passwd_t:s0-s0:c0.c1023 13212 pts/1 00:00:00 passwd
```

На первом терминале нажмите Ctrl+C, чтобы отменить утилиту **passwd**.

В этом примере, когда утилита **passwd** (помеченная типом `passwd_exec_t`) выполняется, процесс оболочки пользователя переходит в домен `passwd_t`. Помните, что **type** определяет домен для процессов и тип для файлов.

Чтобы просмотреть контексты SELinux для всех запущенных процессов, запустите утилиту `ps` повторно. Обратите внимание, что ниже приведен сокращенный пример вывода, который может отличаться в системе пользователя:

```
ps -eZ
```

```
system_u:system_r:dhcpc_t:s0          1869 ? 00:00:00 dhclient
system_u:system_r:sshd_t:s0-s0:c0.c1023 1882 ? 00:00:00 sshd
system_u:system_r:gpm_t:s0           1964 ? 00:00:00 gpm
system_u:system_r:crond_t:s0-s0:c0.c1023 1973 ? 00:00:00 crond
system_u:system_r:kerneloops_t:s0    1983 ? 00:00:05 kerneloops
system_u:system_r:crond_t:s0-s0:c0.c1023 1991 ? 00:00:00 atd
```

Роль `system_r` и пользователь `system_u` используется для системных процессов, таких как демоны.

Источник: https://redos.red-soft.ru/base/redos-8_0/8_0-security/8_0-selinux/8_0-selinux_doc/